

MAPEO DETALLADO GQM+PRAGMATIC → REQUISITOS NORMATIVOS

Matriz: Indicadores MAGERIT Alineados a NIS2, ENS, ISO 27001, NIST

Versión: 2.0 | **Fecha:** Enero 2026 | **Formato:** Tabla completa de conformidad

Indicadores: 20 | **Dimensiones Normativas:** 5 (NIS2, ENS, ISO, NIST, FAIR)

INSTRUCCIONES MATRIZ

- Filas: 20 indicadores MAGERIT (4 por bloque MAR.1-4)
- Columnas: GOAL (GQM) | QUESTION | NIS2 | ENS | ISO 27001 | NIST CSF | Conformidad %
- Uso: Validar que cada indicador cubre requisitos regulatorios
- Auditoría: Auditor externo verifica evidencia indicadores

MATRIZ MAPEO: INDICADORES → NORMAS

BLOQUE MAR.1: CARACTERIZACIÓN ACTIVOS

#	Indicador	GOAL GQM	QUESTION	NIS2	ENS	ISO 27001	NIST CSF	Conformidad
1.1	% Cobertura Inventario Activos	Identificar todos activos críticos	¿Cuántos activos críticos identificados?	Art 21(a) Análisis riesgos	Org.1 Política	A.8.1 Control activos	GV (Govern)	95%
1.2	Compleitud Atributos Valor	Caracterizar impacto c/activo	¿Qué % activos tienen atributos C/I/D/A/T?	Art 21(a) Alcance análisis	Org.1, Org.5	A.5.1 Objetivos seguridad	GV.1 Governace	85%
1.3	Análisis Dependencias	Mapear cascadas riesgo	¿Cuál es la cobertura a análisis dependencias?	Art 21(a) Impacto acumulado	Org.1, Org.6	A.8.1 Relaciones activos	PO (Protect), ID (Identify)	70%
1.4	Trazabilidad Activos → Procesos	Conectar activos a BCP	¿Qué % procesos críticos mapeados?	Art 21(d) Continuidad	Cat.2 BCP	A.17.1 Disponibilidad	RC (Recover)	75%

BLOQUE MAR.2: CARACTERIZACIÓN AMENAZAS

#	Indicador	GOAL GQM	QUESTION	NIS2	ENS	ISO 27001	NIST CSF	Conformidad
2.1	ARO (Annual Rate Occurrence)	Cuantificar frecuencia amenazas	¿Cuál es ARO por amenaza crítica?	Art 21(a) Probabilidad	Med.2, Med.3	A.12.6 Capacidad respuesta	ID.RA (Risk Assessment)	90%
2.2	% Amenazas STRIDE/ CAPEC Mapeadas	Clasificar amenazas sistemáticamente	¿Qué % amenazas clasificadas?	Art 21(a) Tipología riesgos	Med.2	A.12.6 Tipos amenazas	ID.RA	65%
2.3	Degradación Potencial (%)	Estimar pérdida valor por amenaza	¿Cuál es degradación estimada?	Art 21(a) Impacto primario	Med.3 Severidad	A.12.6 Impacto potencial	ID.RA	70%
2.4	Threat Intelligence Actualizada (%)	Integrar contexto geopolítico	¿% amenazas con intel reciente?	Art 21(a) Contexto amenaza	Med.1 Contexto	A.6.1 Información seguridad	ID.RA, PO.OC	85%

BLOQUE MAR.3: CARACTERIZACIÓN SALVAGUARDAS

#	Indicador	GOAL GQM	QUESTION	NIS2	ENS	ISO 27001	NIST CSF	Conformidad
3.1	% Cobertura Salvaguardas	Asignar controles por riesgo	¿% amenazas con salvaguarda?	Art 21(a) Medidas protección	Med.4-5-6 Controles	A.5.1-A.17 Controles	PO (Protect)	95%
3.2	Madurez Salvaguardas (CMM LO-L5)	Evaluar madurez implementación	¿Cuál es madurez promedio?	Art 21(a) Eficacia medidas	Med.4 Implantación	A.8.1 Efectividad	PO.AC Control	80%
3.3	Gaps Documentados/ Priorizados	Identificar insuficiencias	¿Cuántos gaps priorizados?	Art 21(a) Plan acción	Med.4 Mejoría	A.12.6 Identificación mejora	PO.RR Risk Response	90%
3.4	Eficacia Salvaguardas (%)	Validar reducción riesgo	¿% reducción riesgo/control?	Art 21(a) Validación medidas	Med.4 Evaluación	A.8.1 Efectividad	PO.DA Detective	70%

BLOQUE MAR.4: ESTIMACIÓN RIESGO RESIDUAL

#	Indicador	GOAL GQM	QUESTION	NIS2	ENS	ISO 27001	NIST CSF	Conformidad
4.1	ALE Total (€/año)	Cuantificar riesgo en €	¿Cuál es ALE total actual?	Art 21(a) Tolerancia riesgo	Med.1-6 Riesgo residual	A.12.6 Aceptación riesgo	ID.RA	90%
4.2	Residual por Categoría a ENS	Validar proporcionalidad	¿% conformidad proporcionalidad?	Art 21 (implícito)	Proporcionalidad L2-L4	A.6.1 Contexto	ID.RA	85%
4.3	Cascadas Multiactivo (Impacto)	Modelar riesgos acumulados	¿Impacto cascada vs. independiente?	Art 21(a) Impacto acumulado	Med.1 Contexto	A.17.1 Interdependencias	ID.RA, RC	60%
4.4	ROI Salvaguardas (Payback meses)	Priorizar inversión	¿Payback medio salvaguardas?	Implícito (decisión negocio)	(Implícito)	A.14.1 Gestión proyectos	N/A (Estrategia)	100%

MATRIZ CONFORMIDAD NORMATIVA

Por Norma (Cobertura %)

Norma	% Indicadores Alineados	Requisitos Cubiertos	Brechas
NIS2 (Entidades Esenciales)	95%	Art 21(a), 21(d), 21(g-h)	Plan acción específico
ENS RD 311/2022	90%	Org.1-6, Med.1-6, Cat.1-3	Auditoría periódica
ISO 27001:2022	85%	A.5.1, A.6.1, A.8.1, A.12.6, A.14.1, A.17.1	9 controles adicionales
NIST CSF 2.0	88%	Govern, Identify, Protect, Detect, Respond, Recover	Govern detallado
FAIR (Factor Analysis)	100%	TEF, LM, Control Strength, ALE	Integración completa

Por Indicador (Alcance Regulatorio)

Indicador	Requisitos NIS2	Requisitos ENS	Requisitos ISO
% Inventario	Art 21(a) § 1	Org.1	A.8.1
Compleitud Atributos	Art 21(a) § 2	Org.5	A.5.1
Análisis Dependencias	Art 21(a) § 3	Org.6	A.8.1
Trazabilidad Activos	Art 21(d)	Cat.2	A.17.1
ARO Amenaza	Art 21(a) § 4	Med.2	A.12.6
Threat Intel	Art 21(a) § 4	Med.1	A.6.1
Cobertura Salvaguardas	Art 21(a) § 5	Med.4-6	A.5.1
Madurez CMM	Art 21(a) § 5	Med.4	A.14.1
ALE Total	Art 21(a) § 6	Med.1-6	A.12.6

MATRIZ TRAZABILIDAD: INDICADOR → EVIDENCIA AUDITORIA

Cuando auditor externo valida conformidad, requiere:

Indicador	Evidencia Requerida	Responsable	Frecuencia
% Inventario	CMDB (export), Auditoría interna	CISO	Anual
Compleitud Atributos	Reporte CMDB, Validación L1-L5	Data manager	Semestral
Análisis Dependencias	Documento MAR.1 (Tarea 1)	Risk manager	Anual
ARO Amenaza	INCIBE-CERT data, Histórico incidentes	Analyst	Trimestral
Threat Intel	Feeds MITRE ATT&CK, Reportes	SOC manager	Semanal
Cobertura Salvaguardas	Matriz control-amenaza, CMDB	CISO	Trimestral
ALE Total	Cálculo FAIR, BIA, Validación CFO	CFO + Risk	Trimestral
ROI Salvaguardas	Business case, Presupuesto aprobado	CFO	Anual

CRITERIOS ACEPTACIÓN AUDITORÍA

Nivel	Conformidad %	Acción Auditor
✓ Verde	≥85%	Conforme, auditar muestreo
● Amarillo	70-84%	No conforme, plan acción 3m
● Rojo	<70%	No conforme crítico, acción inmediata

Indicadores actuales (promedio): 82% → Status AMARILLO → Plan mejora 3 meses

PLAN DE MEJORA PRIORIZADO

Indicadores a Reforzar (Conformidad <75%)

1. **Análisis Dependencias (70%)**
2. **Acción: Invertir herramienta PILAR (€30K)**
3. **Timeline: 6 meses**
4.
Impacto: +15% conformidad
5.
% Amenazas STRIDE/CAPEC (65%)
6. **Acción: Threat modeling formales con consultor**
7. **Timeline: 4 meses**
8.
Impacto: +20% conformidad
9.
Cascadas Multiactivo (60%)
10. **Acción: Simulación Montecarlo FAIR**
11. **Timeline: 3 meses**
12.
Impacto: +25% conformidad
13.
Eficacia Salvaguardas (70%)
14. **Acción: Pentesting anual formalizado (NIST 800-15)**
15. **Timeline: Continuo**
16. **Impacto: +20% conformidad**
- Impacto: +15% conformidad**
- % Amenazas STRIDE/CAPEC (65%)**
- Impacto: +20% conformidad**
- Cascadas Multiactivo (60%)**
- Impacto: +25% conformidad**

Eficacia Salvaguardas (70%)

Total Inversión Mejora: €50-75K | ROI Conformidad: +20-25% (1 año)

CONCLUSIÓN

Status Actual: 82% conformidad normativa (AMARILLO)

Target: 95%+ (Verde) en 12 meses

Ruta: 4 mejoras prioritarias + 3 herramientas + 6-12 meses implementación

© 2026 Mapeo GQM+PRAGMATIC Normativo | Consorcio Ciberseguridad

Matriz de conformidad auditable: indicadores + requisitos regulatorios integrados.